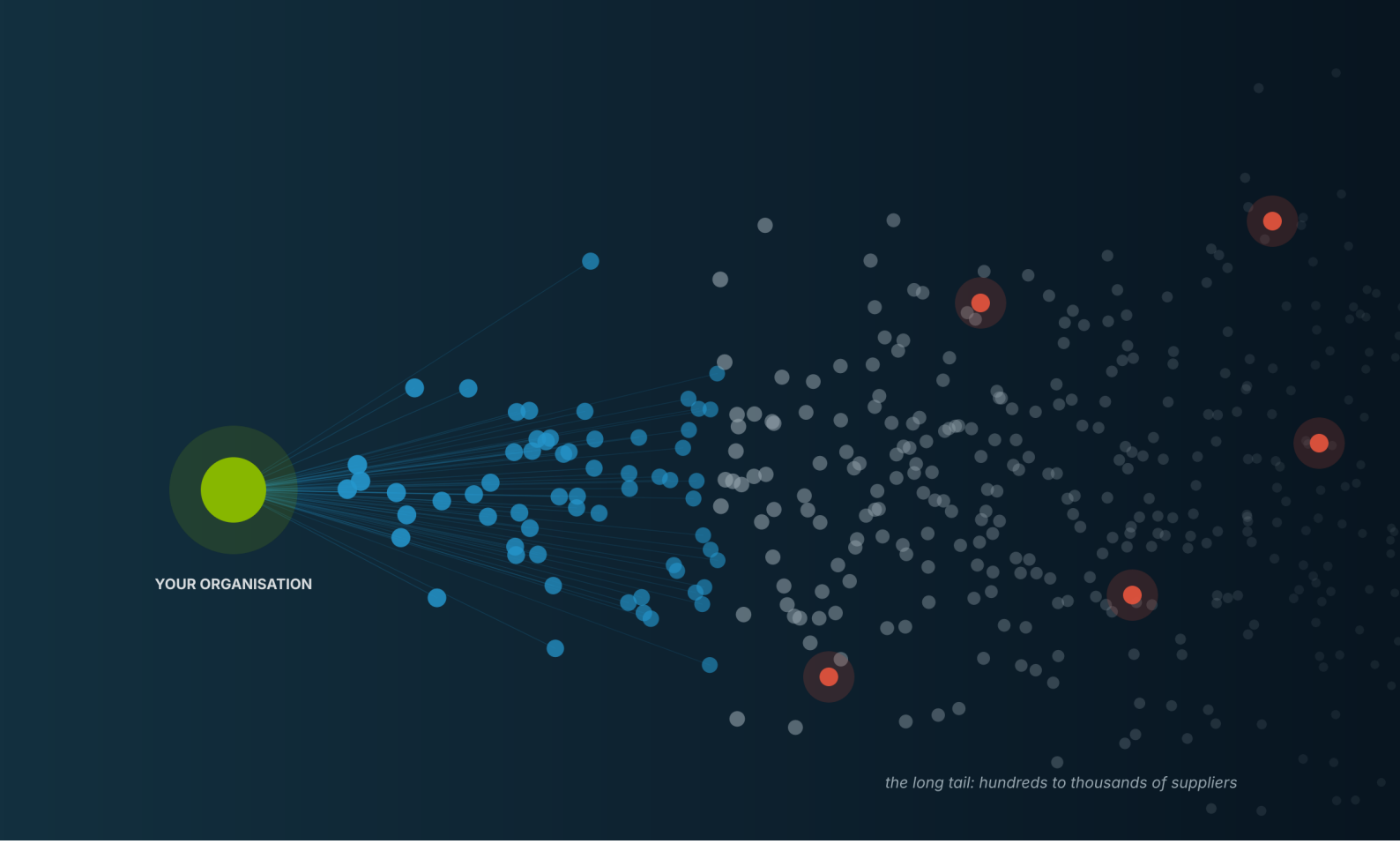


the long tail: hundreds to thousands of suppliers

EXECUTIVE SUMMARY · CYBER SUPPLY CHAIN RISK

Don’t Let the Long Tail Be Your Blind Spot

How the explosion in AI vulnerabilities is reshaping cyber supply chain risk, and why continuous Breach Monitoring across hundreds to thousands of suppliers is now a board-level requirement.

Cytidel

October 2026 · cytidel.com

EXECUTIVE SUMMARY

The supply chain is now a software estate, and AI is multiplying the risk inside it

Most organisations still picture their supply chain as a list of vendors. It is a sprawling, constantly changing software estate: SaaS platforms, managed services, logistics partners, component makers, and the open-source and AI building block every one of them runs on. **Your risk now extends to every line of code your suppliers depend on.**

That estate is being flooded with new vulnerabilities. A record **48,185 CVEs** were published in 2025, around 132 every day. AI-related vulnerabilities grew almost twice as fast as the market overall, and in 2026 AI-assisted discovery has pushed monthly disclosures to double their January level. Attackers are using the same AI to weaponise flaws faster than defenders can patch them.

Meanwhile, the breach routes that matter most increasingly run through third parties. Verizon’s 2025 DBIR found the share of breaches involving a third party **doubled to 30%**. Yet most third-party risk programmes still rely on annual questionnaires, a monitored shortlist of strategic suppliers, and the hope that a supplier will tell you when something goes wrong.

The result is a **long tail**: hundreds to thousands of suppliers sitting outside any continuous oversight. That is exactly where attackers look for the path of least resistance.

48,185
CVEs published in 2025, an all-time high
CVE Data Review 2025

+34.6%
growth in AI-related CVEs, nearly 2x the market
Trend Micro, 2026

30%
of breaches now involve a third party, doubled YoY
Verizon DBIR 2025

51 days
average Cytidel lead time ahead of CISA KEV
Cytidel benchmark

THE BOTTOM LINE

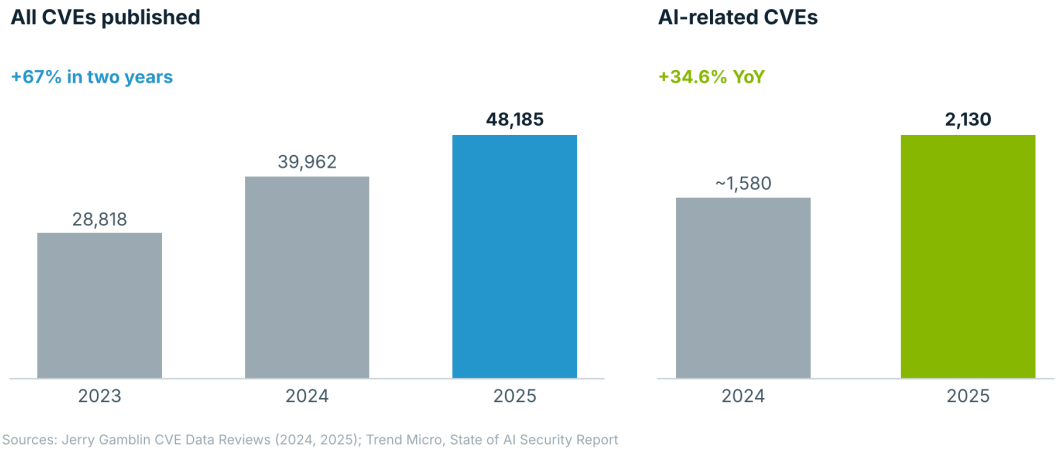
You cannot assess your way out of a real-time problem. Supply chain risk now moves at the speed of exploitation, and **oversight has to move with it.**

Cytidel’s **Breach Monitoring** gives security and risk leaders continuous, intelligence-led visibility across their entire supplier base, with **advanced early warning** on emerging and pre-CVE vulnerabilities, **dedicated AI vulnerability intelligence**, and **threat actor mapping** that shows who is exploiting what. No supplier cap, no waiting to be told.

01 · THE NEW THREAT LANDSCAPE

The AI vulnerability explosion

Vulnerability volume has been climbing for a decade, but the last two years have broken the curve. Published CVEs rose **67% in two years**, from 28,818 in 2023 to 48,185 in 2025. Behind that headline sits a structural shift: AI is now accelerating both sides of the equation.



Sources: Jerry Gamblin CVE Data Reviews (2024, 2025); Trend Micro, State of AI Security Report

Figure 1. Total CVE volume and AI-related CVE growth

AI is creating a new class of exposure

- **AI is the fastest-growing category.** Trend Micro counted **2,130 AI-related CVEs in 2025**, up 34.6% year on year and the highest share of all CVEs ever recorded.
- **Brand-new attack surfaces appear almost overnight.** Model Context Protocol (MCP) servers, the connectors that let AI agents act on enterprise systems, went from virtually no CVEs to **95 in 2025 alone**.
- **The AI supply chain is the riskiest layer.** Nearly half (46.5%) of AI supply chain vulnerabilities are rated High or Critical, the highest concentration of any AI category.
- **Hygiene is lagging adoption.** Researchers found 113,000+ internet-exposed Ollama inference servers, most running outdated software without authentication.

AI is also accelerating discovery and exploitation

Google’s threat intelligence analysis, published in September 2026, shows monthly vulnerability disclosures **doubling from 5,045 in January to 10,477 in July 2026**. More exploited vulnerabilities were observed in the first eight months of 2026 (141) than in all of 2025 (127). AI-discovered vulnerabilities are also nastier: **50% enable remote code execution**, against 26% for the rest.

> *AI hasn’t just added a new category of vulnerability. It has changed the speed of the whole game. Exploitation now often comes before a patch; a CVE record or a scanner signature exists.*

For a single organisation, that is a prioritisation problem. Multiplied across hundreds or thousands of suppliers, each adopting AI tools, agents and open-source models at their own pace and often without telling you, it becomes a **supply chain visibility crisis**.

02 · WHY AI BREAKS SUPPLY CHAIN RISK

The long tail is where the risk hides

Third-party risk programmes were built for a slower world. They concentrate effort on a strategic tier, usually the few dozen suppliers with the biggest contracts, and assess them periodically. Everyone else sits in the long tail: smaller software vendors, niche service providers, sub-processors and the fourth parties behind them.



Figure 2. Oversight concentrates on a strategic few. Exposure is spread across the many.

Attackers understand this better than anyone. As Security Scorecard’s research puts it, threat actors are **prioritising third-party access for its scalability**: compromise one supplier and you inherit a path into every customer it serves.

35.5%
of breaches in 2024 were third-party related
Security Scorecard 2025

46.75%
of third-party breaches involved technology products and services
Security Scorecard 2025

41.4%
of ransomware attacks now start through third parties
Security Scorecard 2025

How AI widens the gap

- **Your suppliers are adopting AI faster than you can assess it.** Each new copilot, agent or model integration adds dependencies, and vulnerabilities, that no annual questionnaire captured.
- **Shared components create shared exposure.** A single flaw in a popular ML framework, inference server or MCP connector can surface across dozens of suppliers at once.
- **The official record is falling behind.** With NVD enrichment backlogs and record disclosure volumes, waiting for formal CVE analysis or a CISA KEV listing means acting weeks after attackers have.
- **Your scanner cannot see your suppliers.** Vulnerability scanners only cover assets you own and have agents on. A supplier’s SaaS platform, AI stack or breached environment is invisible to them.

03 · THE AS-IS REALITY

Six challenges holding supply chain oversight back

Across the security and risk leaders we work with, from automotive and manufacturing to financial services, the same pattern repeats. These are not failures of effort. They are the limits of a model designed before AI changed the pace of risk.

01
Point-in-time assurance in a real-time threat landscape

Annual questionnaires and certifications describe a supplier’s posture on the day they were completed. **Exploitation now moves in hours and days**, not audit cycles.

02
Capped coverage, uncovered long tail

Legacy monitoring services often cap coverage at a few dozen suppliers. One manufacturer we work with was limited to **40 suppliers** against a base many times that size.

03
Waiting to be told

Most organisations learn of a supplier breach when the supplier chooses to disclose it. Without that notice, exposure can go **undetected for 20 days or more**. Disclosure is not a control.

04
Severity scores that mislead

CVSS measures theoretical severity, not real-world threat. **30% of vulnerabilities linked to known threat actors in 2025 were rated Low or Medium**, so CVSS-led triage pushes them down the queue.

05
No line of sight to pre-CVE and AI risk

Teams have no dedicated capability for AI-associated vulnerabilities and no early warning before NVD publication or scanner detection. They react **after** the fact.

06
Lean teams, manual triage, context-poor intel

Generic threat feeds lack context, currency and threat actor linkage. Analysts spend their time researching and sorting rather than **deciding and acting**.

CASE IN POINT · GLOBAL LUXURY AUTOMOTIVE MANUFACTURER

A primary supplier to the manufacturer was affected when **one of that supplier’s own suppliers** suffered a breach of its Salesforce environment. Timely disclosure meant the manufacturer was not left blind, but without that notification the exposure could have gone **undetected for 20+ days**.

Its existing intelligence feed was capped at 40 suppliers, lacked threat actor context and offered **no early warning on AI vulnerabilities**. A wider industry cyber incident, reaching it through shared services rather than its own systems, had already exposed the risk.

The conclusion from its security leadership was clear: **reliance on a third party choosing to disclose is not a control.**

04 · WHY CYTIDEL

Breach Monitoring: early warning across the parts of your stack your scanner can’t see

Cytidel is an AI-native exposure intelligence platform built on one premise: **see the threats that matter before your scanner or CISA KEV.** Breach Monitoring extends that intelligence beyond your own estate to your entire supply chain, so the moment a vendor advisory drops, a breach is detected, or a threat actor starts targeting software your suppliers depend on, the right people are alerted.

PILLAR 1

Advanced Early Warning & Prioritisation

Know what is being exploited, in the wild, right now, across the technology your suppliers run.

- **Exploitation** evidence confirmed in real time from thousands of sources
- **Potential** public exploits identified before CISA KEV catches up
- **Dynamic** Risk Rating: Low to High within hours as exploit signals emerge
- **Ranked** by real-world threat, not CVSS alone

PILLAR 2

Pre-CVE & AI Vulnerability Intelligence

Get ahead of the fastest-growing attack surface in the enterprise.

- **AI**-associated vulnerabilities flagged as they emerge
- **Alerts** ahead of NVD publication and scanner detection in many cases
- **Coverage** of AI frameworks, inference servers, agents and connectors
- **Lead** time to plan mitigation before weaponisation

PILLAR 3

Threat Actor Mapping

Know who is targeting your world, before they get to you.

- **Adversaries** mapped to vulnerabilities with full TTP context (Villain Vault)
- **Alias** tracking and campaign history
- **Sector**-relevant targeting, e.g. groups active against manufacturing
- **Surfaces** threat-actor-linked flaws CVSS would deprioritise

Monitor the whole supply chain, without a cap

Breach Monitoring is designed for the long tail. Whether you have 200 suppliers or 2,000, every one is continuously monitored for breach events, vendor advisories, exploitation activity and threat actor targeting. Supplier lists and technology stacks captured at onboarding feed straight into monitoring, and the model matures toward SBOM-level, component visibility.

01
Map
Import supplier lists, software inventories and onboarding data. No artificial supplier cap.

02
Monitor
Continuous watch for breaches, advisories, exploit code and threat actor activity, including pre-NVD and pre-KEV.

03
Prioritise
Every signal scored on exploitation probability and threat actor weight, in your context.

04
Alert & act
Smart Alerts route the one thing that matters to the right owner, in their existing workflow.

From noise to the one alert that matters

More data is not the answer for a lean team. Cytidel’s Smart Alerts filter global signal down to what is relevant to your suppliers and software, then route it to the person who owns the decision, with the context already attached. No manual research required.

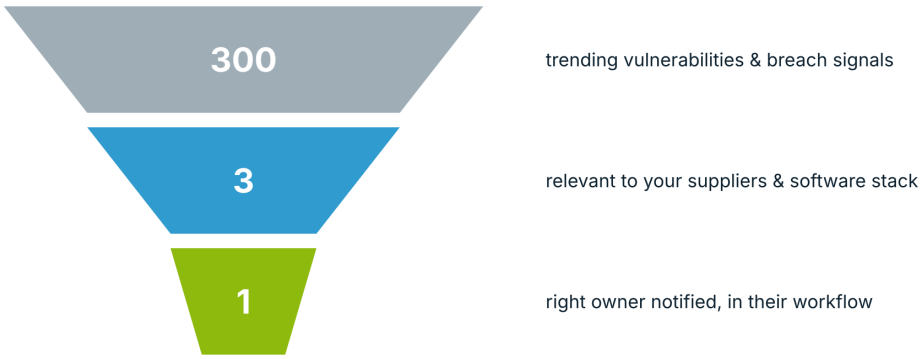


Figure 3. Smart Alerts: from global noise to a single, actionable notification

Closing the window of exposure

The gap between a vulnerability being exploited and that exploitation being officially confirmed is where breaches happen. Cytidel’s early warning moves your decision point to the start of that window, not the end.

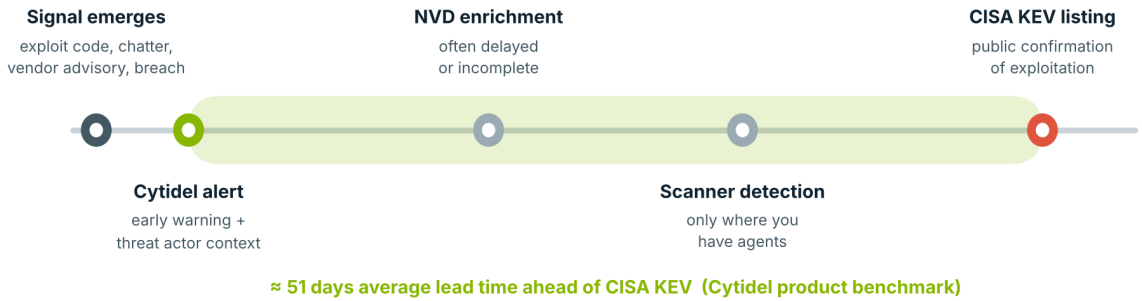


Figure 4. Acting at the signal, not the listing

05 · FROM BLIND SPOT TO OVERSIGHT

What changes with Cytidel Breach Monitoring

	AS IS	WITH CYTIDEL
Coverage	A monitored shortlist of strategic suppliers; the long tail is assessed annually, if at all	✓ **Your** full supplier base monitored continuously, with no artificial cap
Breach detection	Dependent on the supplier choosing to disclose; 20+ days of potential blindness	✓ **Breach** and vulnerability activity at a supplier surfaced before it propagates into your environment
AI vulnerabilities	No dedicated capability; AI risk discovered after scanners or NVD catch up	✓ **Advanced** early warning on AI-associated and pre-CVE vulnerabilities
Prioritisation	CVSS-led, manual, analyst-intensive	✓ **Exploitation**- and threat-actor-led scoring; focus on the ~1% that matters
Threat context	Generic feeds, not current, not linked to adversaries	✓ **Vulnerabilities** mapped to the threat actors exploiting them, with TTPs and sector targeting
Timing	Act on public confirmation (NVD, CISA KEV)	✓ **Act** on the signal, on average 51 days ahead of CISA KEV
Evidence	Hard to show regulators and the board how supplier risk decisions were made	✓ **An** auditable trail behind every priority call, supporting NIS2, DORA and sector regulation

06 · PROOF POINTS

Measured outcomes, not promises

51 days
average lead time ahead of CISA KEV
Cytidel product benchmark

99%+
reduction in vulnerability noise
Cytidel product benchmark

<300
CVEs actioned from ~49,000 over 12 months
Comparable enterprise deployment

80%
up to 80% reduction in patch workload
Cytidel product benchmark

In one benchmark of CVEs linked to active threat actor groups, **34 of 113 carried Low or Medium CVSS scores**. A severity-led process would have deprioritised almost a third of the vulnerability’s attackers were actually using. Cytidel surfaces them regardless of score.

Built for regulated, resilience-driven organisations

Supply chain oversight is no longer optional. **NIS2** and **DORA** put explicit obligations on third-party and ICT supply chain risk, the **EU Cyber Resilience Act** raises the bar for software components, and in automotive, **UNECE R155 and R156** require cyber risk management across the vehicle supply chain. Cytidel is ISO

27001:2022 certified, NIS2 Ready and DORA Ready, and gives boards a measurable view of their progression from reactive to predictive.

07 · START THE CONVERSATION

Five questions every board should be asking

1. **How many suppliers do we have, and how many are continuously monitored today?** If the answer is a few dozen, the long tail is your blind spot.
2. **If one of our long-tail suppliers were breached tonight, how long until we knew?** If the answer depends on them telling us, it is not a control.
3. **Which of our suppliers are running AI components, and are any of them exposed right now?**
4. **Which threat actors are targeting our sector, and which supplier technologies are they exploiting?**
5. **Could we evidence our supplier risk decisions to a regulator tomorrow?**

Conclusion

AI has permanently changed the economics of vulnerability. Discovery is faster, exploitation is faster, and the attack surface now runs deep into every supplier’s technology stack. Organisations that keep managing supply chain risk through annual assessments and capped watchlists will keep learning about supplier breaches from the supplier, or from the attacker.

The alternative is continuous, intelligence-led oversight of the entire supply chain: early warning before the CVE, context on who is exploiting what, and a single, actionable alert for the person who needs to act. **That is what Cytidel Breach Monitoring delivers.**

SEE YOUR LONG TAIL

Don’t let the long tail be your blind spot.

Ask us for a Supplier Exposure Assessment: share your supplier list and we will show you what Breach Monitoring sees across your long tail, including AI and pre-CVE exposures and the threat actors behind them.

cytidel.com/cytidel-platform →

SOURCES & NOTES

CVE volumes: Jerry Gamblin, 2024 and 2025 CVE Data Reviews (jerrygamblin.com).
AI-related CVEs, MCP, AI supply chain severity and exposed AI infrastructure: Trend Micro, “Fault Lines in the AI Ecosystem: State of AI Security Report”. 2024 AI CVE figure derived from the reported 34.6% growth.

2026 disclosure and exploitation trends: Google threat intelligence analysis, reported by SecurityWeek, 30 September 2026.

Third-party statistics: Verizon 2025 Data Breach Investigations Report; SecurityScorecard 2025 Global Third-Party Breach Report.

Cytidel benchmarks (51 days ahead of CISA KEV, 99%+ noise reduction, 49k to <300 CVEs, up to 80% patch workload reduction, 34 of 113): Cytidel product benchmarks and comparable enterprise deployments. 30% threat-actor-linked Low/Medium CVSS: cytidel.com. Case study anonymised.